Vulnerability Management Policy

Cosmaneura, Inc. — Cosma application

Version: 1.0 **Effective:** 2026-04-20 **Next review:** 2027-04-20 **Owner:** CTO / Engineering

1. Purpose

This policy defines how Cosmaneura identifies, tracks, prioritizes, and remediates security vulnerabilities in the Cosma application, its dependencies, and its infrastructure.

2. Scope

- First-party application code (backend and frontend).
- Third-party open-source dependencies (Python, JavaScript, GitHub Actions).
- Infrastructure and platform services (Azure Container Apps, PostgreSQL, Redis, Azure Blob Storage).
- Build and CI tooling (GitHub Actions runners, Nixpacks base images).

3. Sources of findings

Source	What it covers	Cadence
GitHub Dependabot	CVEs in Python (`pip`) and GitHub Actions dependencies	Alerts in real time; version-update PRs monthly
GitHub security advisories	Advisories affecting the repository's ecosystem	Continuous
Vendor notifications	Zoom, Microsoft Azure, Clerk, Recall.ai, AssemblyAI, Sentry, PostHog	As published
Static analysis in CI	Lint / typing findings via Ruff, ESLint, Pyright, TypeScript	Every pull request
Application monitoring	Anomalies surfaced by Sentry	Continuous
External researchers / users	Responsible-disclosure reports to `dev@cosmaneura.com`	Ad hoc

4. Severity classification

Findings are classified using CVSS v3.1 base score, adjusted by application context (exposure, exploitability, and whether the affected component processes PHI). The final severity determines the remediation SLA.

5. Remediation SLAs

Severity	CVSS (base)	Target remediation
Critical	9.0 – 10.0	7 calendar days
High	7.0 – 8.9	30 calendar days
Medium	4.0 – 6.9	90 calendar days
Low	0.1 – 3.9	180 calendar days

Where a vendor patch is not yet available, Cosmaneura applies a compensating control (configuration change, WAF rule, or component isolation) within the same SLA and then backfills the upstream fix when released.

6. Remediation workflow

1. **Triage.** New findings are reviewed within one business day; applicability and severity are confirmed.
2. **Assign.** An engineering owner is recorded against each finding.
3. **Remediate.** The fix ships through the standard pull-request / CI / deploy process; no out-of-band "emergency" merges bypass CI gates.
4. **Verify.** The fix is validated in staging before production rollout for all non-trivial changes.
5. **Close.** The finding is closed with a reference to the merging pull request.

7. Dependency hygiene

- All Python dependencies are pinned via `uv.lock`; all JavaScript dependencies are pinned via `pnpm-lock.yaml`. Reproducible builds are a prerequisite of this policy.
- Dependabot proposes monthly version-update pull requests; they go through the standard review and CI gates before merge.
- `deptry` is run in CI to detect unused dependencies so that unused, outdated packages do not accumulate.

8. Penetration testing & SAST/DAST roadmap

Cosmaneura does not currently engage a third-party firm for periodic application penetration testing and does not operate a dedicated SAST or DAST pipeline. As the customer base and data footprint grow, the company plans to introduce:

- Automated SAST scanning (CodeQL or Semgrep) in CI.
- A scheduled DAST baseline scan (OWASP ZAP) against the staging environment.
- An annual third-party application penetration test.

This roadmap is reviewed at each policy review cycle and updated as milestones are completed.

9. Responsible disclosure

Security researchers are invited to report vulnerabilities to `dev@cosmaneura.com`. We commit to:

- Acknowledge the report within one business day.
- Provide an initial assessment within five business days.
- Remediate in line with the SLAs in §5.
- Refrain from legal action against researchers who act in good faith under this policy and do not access data beyond what is necessary to demonstrate the issue.

10. Review & metrics

This policy is reviewed at least annually. The engineering team tracks and reviews the following metrics at each review:

- Open findings by severity.
- Mean time to remediate, per severity.
- Percentage of findings remediated within SLA.

11. Contact

Vulnerability reports and questions: `dev@cosmaneura.com`